ТУСУР
TUSUR UNIVERSITY

Взаимоотношения с поставщиками

Управление информационной безопасностью. Лекция 2.11

15 Взаимоотношения с поставщиками

Раздел включает в себя 2 категорий и 5 мер обеспечения информационной безопасности:

15.1 Информационная безопасность во взаимоотношениях с поставщиками
Цель: Обеспечить защиту активов организации, доступных поставщикам.

- 15.1.1 Политика информационной безопасности во взаимоотношениях с поставщиками
- 15.1.2 Рассмотрение вопросов безопасности в соглашениях с поставщиками
- 15.1.3 Цепочка поставок информационно-коммуникационных технологий

15.2 Управление услугами, предоставляемыми поставщиком
Цель: Поддерживать согласованный уровень ИБ и предоставления услуги в соответствующих соглашениях с поставщиками.

- 15.2.1 Мониторинг и анализ услуг поставщика
- 15.2.2 Управление изменениями услуг поставщика

Политика информационной безопасности во взаимоотношениях с поставщиками

ТУСУР
TUSUR UNIVERSITY

Требования ИБ, направленные на снижение рисков, связанных с доступом поставщиков к активам организации, должны быть согласованы с поставщиком и задокументированы.

В своей политике организация должна определить и назначить меры обеспечения ИБ, которые относятся к доступу поставщиков к информации организации. Эти меры должны учитывать процессы и процедуры, которые должны выполняться организацией, а также те процессы и процедуры, которые организация должна требовать выполнять от поставщика, включая:

a) определение и документирование типов поставщиков, например ИТ-услуги, логистические услуги, финансовые услуги, компоненты ИТ-инфраструктуры, которым организация будет предоставлять доступ к своей информации;
b) стандартизированный процесс и жизненный цикл для управления отношениями с поставщиками;
c) определение типов доступа к информации, которые будут предоставлены различным типам поставщиков, а также мониторинг и контроль доступа;
d) минимальные требования по ИБ для каждой категории информации и типа доступа, учитывающие деловые потребности и требования организации, а также ее профиль рисков, которые будут служить основой для соглашений уже с конкретным поставщиком;
e) процессы и процедуры для контроля соблюдения установленных требований по ИБ для каждого типа поставщика и типа доступа, включая проверку третьей стороной и проверку продукта;

Политика информационной безопасности во взаимоотношениях с поставщиками

ТУСУР
TUSUR UNIVERSITY

f) правильность и полноту мер обеспечения ИБ для обеспечения целостности информации или обработки информации, проводимой любой из сторон;
g) виды обязательств, применимых к поставщикам для защиты информации организации;
h) обработку инцидентов и непредвиденных обстоятельств, связанных с доступом поставщиков, включая обязанности как организации, так и поставщиков;
i) способность к восстановлению и, если необходимо, меры по восстановлению и устранению непредвиденных обстоятельств для обеспечения доступности информации или обработки информации, предпринимаемые любой из сторон;
j) обучение персонала организации, участвующего в закупках, действующим политикам, процессам и процедурам;
k) обучение персонала организации, взаимодействующего с персоналом поставщика, относительно соответствующих правил взаимодействия и поведения в зависимости от типа поставщика и уровня доступа поставщика к системам и информации организации;
l) условия, при которых требования и меры обеспечения ИБ будут включены в соглашение, подписанное обеими сторонами;
m) управление необходимой передачей информации, устройств обработки информации и чем-либо еще, нуждающимся в передаче, и гарантию того, что безопасность обеспечивается в течение всего периода передачи.

Политика информационной безопасности во взаимоотношениях с поставщиками

ТУСУР
TUSUR UNIVERSITY

При ненадлежащем управлении ИБ информация может подвергаться риску со стороны поставщиков. Должны быть определены и выполняться меры обеспечения ИБ для управления доступом поставщиков к средствам обработки информации. Например, если существует особая необходимость в сохранении конфиденциальности информации, может заключаться соглашение о неразглашении. Другой пример защиты данных от рисков - когда соглашение с поставщиками включает в себя вопросы передачи информации или доступа к информации из-за границы. Организация должна осознавать, что ответственность за соблюдение законодательства и контрактных обязательств по защите информации лежит на самой организации.

Рассмотрение вопросов безопасности в соглашениях с поставщиками

ТУСУР TUSUR UNIVERSITY

Все соответствующие требования по ИБ должны быть установлены и согласованы с каждым поставщиком, который может получить доступ к информации организации, обрабатывать, хранить, передавать информацию или предоставлять соответствующие компоненты ИТ-инфраструктуры.

Соглашения с поставщиками должны быть разработаны и задокументированы, чтобы гарантировать, что между организацией и поставщиком нет недопонимания относительно взаимных обязательств по выполнению соответствующих требований по ИБ.

Для выполнения установленных требований ИБ следует рассмотреть включение в соглашения следующих условий:

a) описание предоставляемой информации или информации, к которой предоставляется доступ, а также методов предоставления информации или получения доступа к ней;
b) категории информации в соответствии с системой категорирования организации; сопоставление, при необходимости, системы категорирования организации с системой категорирования поставщика;
c) законодательные и нормативные требования, включая требования по защите данных, прав на интеллектуальную собственность и авторских прав, а также описание того, как будет обеспечено их соблюдение;

Рассмотрение вопросов безопасности в соглашениях с поставщиками

ТУСУР TUSUR UNIVERSITY

d) обязательства каждой стороны договора по осуществлению согласованного набора мер обеспечения ИБ, включая управление доступом, анализ производительности, мониторинг, отчетность и аудит;
e) правила приемлемого использования информации, включая неприемлемое использование, в случае необходимости;
f) точный перечень персонала поставщика, который авторизован на доступ к информации или получение информации организации, либо процедуры или условия для назначения и аннулирования прав на доступ к информации или получение информации организации персоналом поставщика;
g) политики ИБ, относящиеся к конкретному договору;
h) требования и процедуры по управлению инцидентами (особенно уведомление и совместная работа по устранению последствий инцидентов);
i) требования к обучению и осведомленности о конкретных процедурах и требования к ИБ, например для реагирования на инциденты, процедуры авторизации;
j) соответствующие регламенты для субподряда, включая меры обеспечения ИБ, которые должны выполняться;
k) соответствующие партнеры по соглашению, включая контактное лицо по вопросам ИБ;
l) требования к предварительной проверке персонала поставщика, если таковые установлены, включая обязанности по проведению процедур предварительной проверки и информирования в случае, когда проверка не была завершена или ее результаты дают основания для сомнений или опасений;

Рассмотрение вопросов безопасности в соглашениях с поставщиками

m) право на аудит процессов поставщика и осуществление мер обеспечения ИБ, связанных с соглашением;
n) процессы устранения дефектов и разрешения конфликтов;
o) обязательство поставщика по периодическому предоставлению независимого отчета об эффективности мер обеспечения ИБ и соглашения о своевременном решении соответствующих проблем, упомянутых в отчете;
p) обязательства поставщика по соблюдению требований безопасности организации.

Соглашения могут значительно различаться для разных организаций и разных типов поставщиков. В связи с этим следует уделить внимание тому, чтобы учесть все актуальные риски и требования ИБ. Соглашения с поставщиками могут также допускать участие других сторон (например, субподрядчиков).

В соглашении необходимо учесть процедуры обеспечения непрерывности производственных процессов в случае, если поставщик не в состоянии поставлять свои продукты или услуги, во избежание любых задержек из-за замены продуктов и услуг.

Цепочка поставок информационно-коммуникационных технологий

ТУСУР
TUSUR UNIVERSITY

Соглашения с поставщиками должны содержать требования по рассмотрению рисков ИБ, связанных с цепочкой поставок продуктов и услуг информационно-коммуникационных технологий.

Относительно безопасности цепочек поставок для включения в соглашения с поставщиками должны быть рассмотрены следующие положения:

a) определение требований ИБ, применимых к закупкам продуктов или услуг в области информационно-коммуникационных технологий, в дополнение к общим требованиям ИБ, относящимся к отношениям с поставщиками;
b) для услуг в области информационно-коммуникационных технологий требуется, чтобы поставщики распространяли требования безопасности организации на всю цепочку поставки, если поставщик привлекает подрядчиков для выполнения части услуг в области информационно-коммуникационных технологий, оказываемых организации;
c) для продуктов в области информационно-коммуникационных технологий требуется, чтобы поставщики распространяли соответствующие процедуры, связанные с безопасностью, на всю цепочку поставки, если эти продукты включают в себя компоненты, закупаемые у других поставщиков;
d) выполнение процесса мониторинга и подходящих методов для подтверждения того, что поставляемые продукты и услуги в области информационно-коммуникационных технологий соответствуют заявленным требованиям безопасности;

Цепочка поставок информационно-коммуникационных технологий

ТУСУР
TUSUR UNIVERSITY

e) выполнение процесса определения компонентов продукта или услуги, которые являются критически важными для поддержания функциональности и следовательно требуют повышенного внимания и изучения, если произведены за пределами организации, особенно если первичный поставщик передает на аутсорсинг производство каких-то элементов продукта или услуги другим поставщикам;
f) получение уверенности в том, что критически важные компоненты и их происхождение могут быть прослежены по всей цепочке поставки;
g) получение уверенности в том, что поставляемые продукты в области информационно-коммуникационных технологий функционируют должным образом без каких-либо непредусмотренных или нежелательных функций;
h) определение правил обмена информацией, касающихся цепочки поставки и любых потенциальных проблем и компромиссов между организацией и поставщиками;
i) выполнение конкретных процессов управления жизненным циклом и доступностью компонентов информационно-коммуникационных технологий и связанными с ними рисками безопасности. Это включает в себя управление рисками, связанными с тем, что компоненты более не доступны в силу того, что их поставщики прекратили свою деятельность или прекратили поставку этих компонентов по причине развития технологий.

Цепочка поставок информационно-коммуникационных технологий

Конкретные методы управления рисками в цепочке поставки информационно-коммуникационных технологий основаны на высокоуровневых процедурах обеспечения общей ИБ, качества, управления проектами и разработки систем, но не заменяют их.

Организациям рекомендуется работать с поставщиками для понимания цепочки поставки информационно-коммуникационных технологий и любых вопросов, оказывающих значительное влияние на поставляемые продукты и услуги. Организации могут влиять на методы обеспечения ИБ в цепочке поставок информационно-коммуникационных технологий, четко определяя в соглашениях со своими поставщиками вопросы, которые должны решаться другими поставщиками в цепочке поставок информационно-коммуникационных технологий.

Цепочка поставок информационно-коммуникационных технологий включает в себя услуги облачных вычислений.

Мониторинг и анализ услуг поставщика

Организации должны регулярно проводить мониторинг, проверку и аудит деятельности поставщика по предоставлению услуг.

Мониторинг и анализ услуг, предоставляемых поставщиком, должны обеспечивать уверенность в том, что положения и условия, касающиеся ИБ, отраженные в соглашениях, выполняются и что инциденты и проблемы в области ИБ решаются должным образом.

Это должно реализовываться при управлении услугами через процесс взаимодействия между организацией и поставщиком, чтобы:

a) осуществлять мониторинг уровней предоставления услуг с целью проверки соблюдения условий соглашений;
b) анализировать отчеты об услугах, подготовленные поставщиком, и организовывать регулярные рабочие встречи, как это определено соглашениями;
c) проводить аудиты поставщиков вместе с анализом отчетов независимых аудиторов, если они есть, и осуществлять последующие действия по выявленным проблемам;
d) предоставлять информацию об инцидентах ИБ и анализировать эту информацию в соответствии с требованиями соглашений и любых вспомогательных методических рекомендаций и процедур;
e) анализировать контрольные записи поставщиков и записи о событиях безопасности, эксплуатационных проблемах, сбоях, обнаруженных ошибках и нарушениях, связанных с поставляемой услугой;

Мониторинг и анализ услуг поставщика

f) решать любые выявленные проблемы и управлять ими;
g) анализировать в разрезе аспектов ИБ отношения поставщика с его подрядчиками;
h) гарантировать, что поставщик сохраняет достаточную способность обслуживания согласно работоспособным планам, разработанным для обеспечения согласованных уровней непрерывности обслуживания при значительных сбоях и аварийных ситуациях.

Ответственность за управление отношениями с поставщиками следует возлагать на специально назначенное лицо или группу по управлению услугами. Кроме того, организация должна обеспечить, чтобы поставщики установили обязанности по анализу соответствия и обеспечению выполнения требований соглашения. Должны быть выделены достаточные ресурсы с необходимыми техническими навыками для мониторинга того, что требования соглашения, в частности требования ИБ, выполняются. Необходимо предпринимать соответствующие действия при обнаружении недостатков в оказании услуг.

Организация должна поддерживать достаточный общий контроль и прозрачность всех аспектов безопасности в отношении информации ограниченного доступа или устройств обработки информации, к которым поставщик имеет доступ, использует их или управляет ими. Организация должна поддерживать прозрачность действий, связанных с безопасностью, таких как управление изменениями, выявление уязвимостей, а также составление отчетов об инцидентах ИБ и реагирование на них с помощью установленного процесса оповещения.

Управление изменениями услуг поставщика

Требуется управлять изменениями в предоставляемых поставщиками услугах, включая поддержку и улучшение существующих политик, процедур, а также мер обеспечения ИБ, с учетом категории информации бизнеса, задействованных систем и процессов, а также результатов переоценки рисков ИБ.

Должны быть приняты во внимание следующие аспекты:

a) изменения в соглашениях с поставщиками;
b) изменения, проводимые организацией, для реализации:
    1) улучшения текущих предлагаемых услуг;
    2) разработки любых новых прикладных программ и систем;
    3) изменения или обновления политик и процедур организации;
    4) новых или измененных мер для устранения инцидентов ИБ и повышения безопасности;
c) изменения в услугах поставщика для реализации:
    1) изменения и усовершенствования сетей;
    2) использования новых технологий;
    3) использования новых продуктов или новых версий/выпусков;
    4) использования новых инструментов и сред разработки;
    5) изменения физического расположения средств обслуживания;
    6) смены поставщиков;
    7) заключения контракта с другим субподрядчиком.

Рассмотренные вопросы

Взаимоотношения с поставщиками:

- Вопросы безопасности в соглашениях с поставщиками
- Цепочка поставок информационно-коммуникационных технологий

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!